

# Third-party vendor security assessment

Ten questions for vetting an external software provider before procurement. Blank fields are for the vendor response, score, and reviewer notes.

## SECURITY GOVERNANCE & COMPLIANCE

**1. Do you maintain a formal information security program aligned to a recognized framework (NIST CSF, ISO 27001, SOC 2, or equivalent)? Please name the primary framework(s) used.**

**Expected response.** Yes. Primary framework named (e.g., NIST CSF 2.0, ISO 27001, SOC 2). Evidence of documented policies and assigned ownership exists.

**Evidence requested.** Security policy overview or framework mapping document

**Risk if unsatisfactory.** Lack of structured program indicates immature risk management and higher likelihood of control gaps.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

## SECURITY GOVERNANCE & COMPLIANCE

**2. Have you completed an independent SOC 2 Type II (or equivalent ISO 27001 certification / other independent audit) within the last 12–18 months? If yes, please provide the report or a current bridge letter under NDA?**

**Expected response.** Yes. SOC 2 Type II report (or equivalent) available under NDA. Report period covers recent operations.

**Evidence requested.** SOC 2 Type II report or ISO 27001 certificate + Statement of Applicability

**Risk if unsatisfactory.** Absence of independent assurance increases residual risk; reliance solely on self-attestation is weaker.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

#### DATA PROTECTION

### 3. Is all customer data encrypted in transit using industry-standard protocols (minimum TLS 1.2, preferably TLS 1.3)?

**Expected response.** Yes. TLS 1.2+ enforced for all external and internal connections that carry customer data. Weak protocols disabled.

**Evidence requested.** Architecture diagram or configuration standard showing TLS requirements

**Risk if unsatisfactory.** Unencrypted or weakly encrypted transit exposes data to interception (man-in-the-middle attacks).

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

#### DATA PROTECTION

### 4. Is all customer data encrypted at rest using strong encryption (AES-256 or equivalent)? Who manages the encryption keys (vendor, customer, or third-party KMS)?

**Expected response.** Yes. AES-256 (or equivalent) at rest. Key management clearly described (preferably customer-managed or hardened KMS with separation of duties).

**Evidence requested.** Data encryption policy or technical whitepaper describing encryption & key management

**Risk if unsatisfactory.** Unencrypted data at rest is highly exposed in the event of storage compromise or insider threat.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

#### ACCESS CONTROL & IDENTITY

### 5. Do you enforce multi-factor authentication (MFA) for all administrative, privileged, and remote access to systems that process or store customer data?

**Expected response.** Yes. MFA required for all privileged and remote access. Exceptions are rare, documented, and time-bound.

**Evidence requested.** Access control policy or screenshot/config evidence of MFA enforcement

**Risk if unsatisfactory.** Single-factor access to privileged systems is a leading cause of breaches.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

#### ACCESS CONTROL & IDENTITY

**6. How do you perform periodic user access reviews, and what is your process and timeline for revoking access when employees or contractors are terminated or change roles?**

**Expected response.** Formal access reviews at least quarterly. Access revoked within 24 hours of termination (or same day for high-risk roles).

**Evidence requested.** Access review procedure or sample of recent review evidence (redacted)

**Risk if unsatisfactory.** Orphaned accounts and delayed revocation are common sources of unauthorized access.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

#### INCIDENT RESPONSE & NOTIFICATION

**7. Do you maintain a documented Incident Response (IR) plan that includes defined severity levels, roles, escalation paths, and customer notification procedures?**

**Expected response.** Yes. Documented IR plan exists, is reviewed at least annually, and includes customer notification steps.

**Evidence requested.** IR plan table of contents or redacted IR policy excerpt

**Risk if unsatisfactory.** Without a tested IR plan, response to incidents is ad-hoc and notification delays are likely.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

#### INCIDENT RESPONSE & NOTIFICATION

**8. What is your standard contractual commitment for notifying affected customers of a security incident that impacts their data (e.g., within 24, 48, or 72 hours of confirmation)?**

**Expected response.** Clear commitment (ideally  $\leq 72$  hours, preferably 24–48 hours) after confirmation of an incident affecting customer data. Alignment with applicable breach-notification laws.

**Evidence requested.** Relevant section of standard DPA / MSA or security addendum

**Risk if unsatisfactory.** Slow or vague notification timelines hinder the customer's own regulatory and contractual obligations.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

## BUSINESS CONTINUITY & RESILIENCE

**9. Do you maintain and regularly test a Business Continuity / Disaster Recovery (BC/DR) plan? How frequently is it tested, and can you share a summary of the most recent test results?**

**Expected response.** Yes. BC/DR plan tested at least annually (tabletop or technical failover). Recent test summary available under NDA.

**Evidence requested.** BC/DR policy excerpt or redacted test summary / attestation

**Risk if unsatisfactory.** Untested recovery plans frequently fail when needed, extending outage impact to customers.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---

## SUB-PROCESSOR / FOURTH-PARTY RISK

**10. Do any sub-processors or sub-contractors have access to customer data? If yes, how do you assess and monitor their security posture, and will you provide a current list of sub-processors upon request?**

**Expected response.** Yes. A maintained list of sub-processors is available. Sub-processors are contractually required to meet equivalent security standards and are subject to due diligence / ongoing monitoring.

**Evidence requested.** Current sub-processor list + description of due-diligence process

**Risk if unsatisfactory.** Unvetted sub-processors create downstream risk that is often invisible to the primary customer.

**Vendor response.**

**Score (1–5).** \_\_\_\_\_

**Reviewer comments.**

---